

INTERNAL AUDIT REPORT

Access Management & Vendor Management

Organization: VertexPay Solutions

Audit Period: 1 January 2026 – 30 June 2026

Report Date: 21 July 2026

Auditor: Internal Audit Team

1. Executive Summary

An internal audit was conducted to assess the effectiveness of Access Management and Vendor Management controls at VertexPay Solutions. The audit covered identity and access management across Azure AD, AWS, and Microsoft 365, as well as the governance of third-party vendors with access to company systems, customer PII, and payment-related services.

The audit identified control weaknesses in the execution of periodic access reviews and ongoing vendor risk management. The Q2 access review was not performed, and vendor security assessments were performed during onboarding without evidence of ongoing periodic reassessment. These weaknesses increase the risk that inappropriate user access or changes in third-party risk may remain unidentified.

Overall, the control environment is assessed as **PARTIALLY EFFECTIVE IMPROVEMENT REQUIRED**. Core policies and onboarding processes exist, but certain monitoring and periodic review controls are not operating consistently as designed.

2. Audit Scope

The audit covered the following areas:

Access Management

- User provisioning
- User deprovisioning
- Joiner, mover, and leaver processes
- Periodic user access reviews
- Privileged access management
- Access review exception remediation
- Azure AD / Microsoft Entra ID
- AWS access
- Microsoft 365 administrative access

Vendor Management

- Vendor onboarding and due diligence
- Vendor risk classification
- Security assessments
- Contractual security requirements
- Ongoing vendor monitoring
- Periodic vendor reassessment
- Critical third-party payment processor oversight
- Vendors with access to customer PII or company systems

Audit Period: 1 January 2026 – 30 June 2026

3. Audit Objectives

The audit objectives were to determine whether:

1. User access is appropriately approved and periodically reviewed.
2. Access is removed appropriately when employees change roles or leave the organization.
3. Privileged access is appropriately controlled and monitored.
4. Vendors are appropriately assessed and risk-classified before onboarding.
5. Vendor security risks are monitored throughout the vendor relationship.
6. High-risk and critical vendors are periodically reassessed.
7. Evidence is retained to demonstrate the operation of key controls.

4. Audit Criteria

The audit was performed against the following criteria:

- VertexPay Access Control Policy
- User Access Management Procedure
- Privileged Access Management Procedure
- Joiner-Mover-Leaver Procedure
- Third-Party Risk Management Policy
- Vendor Management Procedure
- Supplier Security Requirements
- ISO/IEC 27001:2022 requirements relating to access control and supplier relationships
- Applicable PCI DSS requirements
- Internal control requirements established by VertexPay Solutions

5. Audit Methodology

The audit used a risk-based internal audit methodology consisting of:

- Review of relevant policies and procedures
- Inspection of access management records
- Inspection of vendor risk management records
- Review of Q1 and Q2 access review evidence
- Review of vendor onboarding and assessment records
- Sample-based testing of access management controls
- Review of privileged access listings
- Interviews with the IT Director and Head of Vendor Risk
- Examination of remediation and closure evidence
- Comparison of actual control operation against defined criteria

6. Audit Findings

Finding ID	Description	Classification
F-001	The required Q2 periodic access review was not performed or documented.	Major Nonconformity
F-002	Vendor security assessments were performed at onboarding, but no ongoing periodic vendor reassessments were performed.	Major Nonconformity
F-003	Ongoing monitoring of vendor security posture was not consistently documented after onboarding.	Minor Nonconformity
F-004	Closure evidence for selected access review exceptions was incomplete.	Observation / Improvement Opportunity

7. Key Risk Implications

The identified weaknesses may result in:

- Inappropriate or excessive user access remaining undetected.
- Former or transferred users retaining unnecessary access.
- Changes in vendor security posture remaining unidentified.
- Increased exposure to third-party security incidents.
- Inadequate evidence to demonstrate ongoing control operation.
- Increased compliance risk in areas involving customer PII and payment-related services.

8. Recommendations

8.1 Strengthen Periodic Access Review Governance

VertexPay should implement a formal mechanism to ensure that scheduled access reviews are completed on time.

Recommended actions include:

- Assigning a clearly accountable control owner.
- Implementing automated review reminders.
- Establishing escalation procedures for overdue reviews.
- Tracking completion through management reporting.
- Defining a documented process for handling missed review cycles.

8.2 Implement Risk-Based Vendor Reassessment

VertexPay should establish and operate a formal periodic vendor reassessment program.

The program should:

- Define reassessment frequencies based on vendor risk.
- Require enhanced reassessment of high-risk and critical vendors.
- Track reassessment due dates.
- Escalate overdue reassessments.
- Retain evidence of completed reassessments.

8.3 Formalize Ongoing Vendor Monitoring

Vendor Risk Management should define minimum ongoing monitoring activities for active vendors.

Monitoring should consider:

- Security incidents
- Changes in vendor risk
- Changes in services or ownership
- Expiration of security certifications
- Relevant assurance reports
- Material security events

8.4 Improve Remediation Evidence Retention

VertexPay should standardize the evidence required to close access management exceptions.

Closure evidence should clearly demonstrate:

- What issue was identified.
- What corrective action was taken.
- Who completed the action.
- When the action was completed.
- How the action was verified.

9. Management Action Summary

Finding ID	CAPA ID	Action Owner	Target Date	Status
F-001	CAPA-001	IT Director	31 August 2026	Open
F-002	CAPA-002	Head of Vendor Risk	30 September 2026	Open
F-003	CAPA-003	Head of Vendor Risk	30 September 2026	Open
F-004	CAPA-004	IAM Manager	31 August 2026	Open

10. Conclusion

The audit concludes that VertexPay Solutions has established core Access Management and Vendor Management processes. However, the operating effectiveness of certain periodic monitoring and review controls requires improvement.

The most significant issues relate to the missed Q2 access review and the absence of ongoing periodic vendor reassessments. These weaknesses indicate that control activities are not consistently operating at the frequency required to provide ongoing assurance.

Overall Audit Conclusion

PARTIALLY EFFECTIVE IMPROVEMENT REQUIRED

Management should prioritize the implementation of the CAPA plans, particularly the establishment of reliable tracking, ownership, escalation, and verification mechanisms for periodic control activities.

A follow-up audit or management verification review should be performed after implementation to confirm that:

1. Access reviews are completed on schedule for at least two consecutive review periods.
2. High-risk and critical vendors are reassessed according to the approved risk-based schedule.
3. Ongoing vendor monitoring is consistently documented.
4. Access review remediation records contain complete closure evidence.

11. Audit Completion Status

Audit Component	Status
Annual Audit Plan	Completed
Audit Program	Completed
Audit Checklists	Completed
Evidence Review	Completed
Interviews	Completed
Findings Log	Completed
Nonconformity Register	Completed
CAPA Tracker	Completed
Executive Audit Report	Completed